09 — Déclaration d'applicabilité (SoA)

Document	Déclaration d'applicabilité, ISO/IEC 27001:2022, clause 6.1.3 d)
Version	1.0 — octobre 2026
Statut	Décisions proposées, à valider avec les propriétaires de risques et approuver par la direction
Registre détaillé	registres/Registres_SMSI.xlsx, onglet SoA
Organisation	Carthago FinTech (organisation fictive, étude de cas pédagogique)

1. Objet

La SoA indique, pour chacun des 93 contrôles de l'Annexe A, s'il est applicable au SMSI, pourquoi, quels risques il traite, quelles actions du plan le mettent en œuvre et où en est sa mise en œuvre. Elle relie ainsi les risques (08) aux mesures de sécurité.

2. Méthode

1. Partir des 93 contrôles de l'Annexe A de la norme.
2. Pour chacun, chercher les risques du registre qui le visent et les écarts du cas qu'il traite.
3. Déclarer **applicable** un contrôle lié à un risque, à un écart ou à une exigence du périmètre ; déclarer **non applicable** seulement avec une justification tirée du cas.
4. Estimer l'état de mise en œuvre d'après l'énoncé du cas : **Implémentée**, **Partielle** ou **À planifier**.
5. Relier chaque contrôle applicable partiel ou à planifier à au moins une action du plan de traitement.

3. Résultats

- **88 contrôles applicables** et **5 non applicables** sur 93.
- Parmi les applicables : 5 implémentés, 52 partiels, 31 à planifier.
- Chaque contrôle applicable est relié à au moins un risque, et chaque contrôle applicable partiel ou à planifier à au moins une action.

Thème	Applicables	Non applicables	Implémentés	Partiels	À planifier
Organisationnelles	37	0	1	26	10
Personnes	8	0	0	3	5
Physiques	10	4	0	1	9
Technologiques	33	1	4	22	7

4. Contrôles non applicables

Contrôle	Justification	À réexaminer si
7.5 Protection contre les menaces physiques et environnementales	Pas de centre de données de production au siège ; la protection de l'infrastructure de production relève de Microsoft Azure (§4), suivie par A.5.22 et A.5.23.	Une salle serveurs ou un centre de données est identifié au siège
7.6 Travail dans les zones sécurisées	Aucune zone sécurisée de production au siège (§4) ; à réexaminer si une salle serveurs est identifiée.	Une salle serveurs ou un centre de données est identifié au siège
7.11 Services supports	Pas de centre de données au siège ; l'alimentation des environnements de production est gérée par Azure (§4).	Une salle serveurs ou un centre de données est identifié au siège
7.12 Sécurité du câblage	Câblage de bureau standard sans enjeu identifié ; pas de câblage de centre de données au siège (§4). Hypothèse à confirmer.	Une salle serveurs ou un centre de données est identifié au siège
8.30 Développement externalisé	Aucun développement externalisé n'est mentionné dans le cas ; à réexaminer si des prestataires interviennent sur le code.	Des prestataires interviennent sur le code

5. Contrôles applicables à mettre en place en priorité

Les 31 contrôles applicables dont l'état est « À planifier » n'ont, d'après le cas, aucun élément de mise en œuvre mentionné. Ils sont regroupés dans les actions T-30 à T-36 du plan de traitement et à vérifier en atelier : une mise en œuvre existante peut ne pas figurer dans l'énoncé.

Contrôle	Intitulé
5.5	Contacts avec les autorités
5.6	Contacts avec des groupes d'intérêt spécifiques
5.8	Sécurité de l'information dans la gestion de projet
5.28	Collecte de preuves
5.31	Exigences légales, statutaires, réglementaires et contractuelles
5.32	Droits de propriété intellectuelle
5.33	Protection des enregistrements
5.34	Protection de la vie privée et des données à caractère personnel (DCP)
5.35	Révision indépendante de la sécurité de l'information
5.36	Conformité aux politiques, règles et normes de sécurité de l'information
6.1	Sélection des candidats
6.2	Termes et conditions du contrat de travail
6.4	Processus disciplinaire
6.5	Responsabilités après la fin ou le changement d'un emploi
6.8	Déclaration des événements de sécurité de l'information
7.1	Périmètres de sécurité physique
7.2	Les entrées physiques
7.3	Sécurisation des bureaux, des salles et des installations
7.4	Surveillance de la sécurité physique
7.7	Bureau propre et écran vide
7.8	Emplacement et protection du matériel
7.10	Supports de stockage
7.13	Maintenance du matériel
7.14	Élimination ou recyclage sécurisé du matériel
8.10	Suppression des informations
8.12	Prévention de la fuite de données
8.17	Synchronisation des horloges
8.18	Utilisation de programmes utilitaires à privilèges
8.23	Filtrage web
8.26	Exigences de sécurité des applications
8.34	Protection des systèmes d'information pendant les tests d'audit

6. Limites et hypothèses

- L'état de mise en œuvre est une **estimation** fondée sur l'énoncé : un contrôle « À planifier » peut exister sans être mentionné, et un contrôle « Implémentée » reste à vérifier par des preuves.
- Les décisions d'applicabilité reposent sur les risques cotés (document 08) et sur le périmètre proposé ; elles devront être revues si le périmètre ou les cotations évoluent.
- Le risque physique du siège (R-12) est coté sur des hypothèses : le cas décrit peu le siège.
- Les liens entre contrôles, risques et actions sont indicatifs et à justifier lors des ateliers.

7. Approbation

Rôle	Nom	Décision	Date
Chef de programme	Nader Bouaziz (CISO)	À approuver	
Sponsor	Amel Ben Salem (CEO)	À approuver	

(Personnes fictives de l'étude de cas.)